

Day 33 - Project: Detection Engineering Assessment

Enterprise Security Detection Design & Monitoring Framework

Prepared By:

Adithya Raj K R

Role:

SOC Analyst Intern

Project Title:

Enterprise Detection Engineering Assessment

Table of Contents

1. Executive Summary
2. Business Scenario
3. Project Objectives
4. Detection Catalogue
5. MITRE ATT&CK Mapping Table
6. Detection Use Case 1 – Suspicious PowerShell Execution
7. Detection Use Case 2 – Brute Force Authentication Attack
8. Detection Use Case 3 – Privilege Escalation Activity
9. Detection Use Case 4 – Data Exfiltration Attempt
10. Detection Use Case 5 – Ransomware Behavior Detection
11. Alert Triage Guide
12. False Positive Analysis
13. Tuning Recommendation
14. Final SOC Recommendation Report
15. Evaluation Criteria
16. Conclusion

Executive Summary

The purpose of this Detection Engineering Assessment is to design enterprise-grade security detections that improve the organization's ability to identify cyber threats, reduce attacker dwell time, and strengthen Security Operations Center (SOC) monitoring capabilities.

The organization has recently experienced increased ransomware activity, credential theft attempts, and suspicious PowerShell executions. To address these threats, five security detection use cases were developed focusing on endpoint security, authentication monitoring, privilege abuse detection, data protection, and ransomware prevention.

Each detection use case includes:

- Threat Scenario
- Workflow
- Workflow Explanation
- Detection Logic
- Alert Generation Conditions
- MITRE ATT&CK Mapping
- Required Log Sources
- Severity Classification
- False Positive Analysis
- Response Actions
- Tuning Recommendations

These detections provide comprehensive coverage against modern attack techniques while improving investigation efficiency and reducing incident response time.

Business Scenario

The organization has observed:

- Increased ransomware incidents
- Credential theft attempts
- Suspicious PowerShell executions
- Privilege abuse activities
- Potential insider threat behavior

The SOC Manager requires enhanced monitoring and detection capabilities to identify threats early and improve overall security posture.

Project Goals:

- Reduce Mean Time To Detect (MTTD)
- Reduce Mean Time To Respond (MTTR)

- Improve detection accuracy
- Strengthen SOC monitoring
- Improve incident response efficiency

3. Project Objectives

The objectives of this project are:

- Design enterprise-grade security detections
- Improve attack visibility
- Map detections to MITRE ATT&CK
- Reduce false positives
- Create response workflows
- Improve threat investigation
- Enhance SOC operational efficiency

Detection Catalogue

ID	Detection Use Case	Severity	ATT&CK Technique
UC-01	Suspicious PowerShell Execution	High	T1059.001
UC-02	Brute Force Authentication Attack	High	T1110
UC-03	Privilege Escalation Activity	Critical	T1078, T1098
UC-04	Data Exfiltration Attempt	Critical	T1041
UC-05	Ransomware Behavior Detection	Critical	T1486

MITRE ATT&CK Mapping Table

Use Case	ATT&CK Tactic	Technique ID	Technique
Suspicious PowerShell	Execution	T1059.001	PowerShell
Brute Force Attack	Credential Access	T1110	Brute Force
Privilege Escalation	Privilege Escalation	T1078	Valid Accounts
Privilege Escalation	Persistence	T1098	Account Manipulation
Data Exfiltration	Exfiltration	T1041	Exfiltration Over C2

Ransomware	Impact	T1486	Data Encrypted for Impact
------------	--------	-------	---------------------------

Use Case 1: Suspicious PowerShell Execution

Description

PowerShell is a legitimate Windows administration tool frequently abused by attackers for malware delivery, persistence, lateral movement, and ransomware deployment.

Threat Scenario

An attacker gains access to a workstation through phishing and launches an encoded PowerShell command to download malware from an external server.

Detection Workflow

User Executes PowerShell

↓

PowerShell Logs Generated

↓

SIEM Correlation

↓

Encoded Command Detected

↓

Alert Generated

↓

SOC Investigation

Workflow Explanation

The endpoint generates PowerShell execution logs. The SIEM analyzes command-line arguments and identifies suspicious indicators such as Base64 encoding, obfuscation, or remote file downloads. If malicious patterns are detected, a high-severity alert is generated.

Detection Logic

Generate Alert If:

PowerShell Execution Detected

AND

Command Contains:

- EncodedCommand
- IEX
- DownloadString
- Invoke-WebRequest

THEN

Generate Suspicious PowerShell Alert

Example

powershell.exe -EncodedCommand SQBmACgA...

Log Sources

- Windows Event Logs
- PowerShell Logs
- Sysmon
- EDR Telemetry

Severity

HIGH

False Positives

- IT administration scripts
- Automated software deployment
- Patch management tools

Response Actions

- Validate command execution
- Review user activity
- Isolate endpoint if malicious
- Block malicious domains

Tuning Recommendations

- Whitelist approved scripts
- Exclude management servers
- Baseline normal PowerShell activity

Use Case 2: Brute Force Authentication Attack

Description

Detects repeated authentication failures indicating password spraying or brute-force attacks.

Threat Scenario

An attacker attempts hundreds of login attempts against VPN accounts using leaked credentials.

Detection Workflow

Authentication Logs

↓

Multiple Failed Logins

↓

SIEM Correlation

↓

Threshold Exceeded

↓

Brute Force Alert

↓

SOC Investigation

Workflow Explanation

The SIEM continuously monitors authentication logs and counts failed login attempts from users or source IPs. When a threshold is exceeded within a specific time period, an alert is generated.

Detection Logic

Generate Alert If:

Failed Login Attempts > 10

AND

Time Window < 5 Minutes

AND

Source IP External

THEN

Generate Brute Force Alert

Example

User: admin

Failed Attempts: 25

Source IP: External

Log Sources

- Active Directory
- VPN Logs
- Firewall Logs
- Azure AD

Severity

HIGH

False Positives

- Forgotten passwords
- Misconfigured applications
- Service account failures

Response Actions

- Lock account
- Block source IP
- Force password reset
- Review login history

Tuning Recommendations

- Use adaptive thresholds
- Exclude service accounts
- Implement geolocation analysis

Use Case 3: Privilege Escalation Activity

Description

Detects unauthorized assignment of administrative privileges.

Threat Scenario

A compromised user account is added to the Domain Admins group by an attacker.

Detection Workflow

User Account Activity

↓

Privilege Assignment

↓

SIEM Correlation

↓

Domain Admin Change

↓

Critical Alert

↓

SOC Investigation

Workflow Explanation

Group membership changes are monitored. If a user receives privileged access without approved change records, the SIEM generates a critical alert.

Detection Logic

Generate Alert If:

User Added To Domain Admins

OR

Administrator Privileges Assigned

THEN

Generate Privilege Escalation Alert

Example

User: john.doe

Added To: Domain Admins

Log Sources

- Active Directory
- Windows Security Logs
- Identity Management Systems

Severity

CRITICAL

False Positives

- Authorized administrator changes
- Planned maintenance

Response Actions

- Validate approval
- Remove unauthorized access
- Investigate account compromise

Tuning Recommendations

- Integrate change management systems
- Whitelist approved admin accounts

Use Case 4: Data Exfiltration Attempt

Description

Detects unauthorized transfer of sensitive organizational data.

Threat Scenario

A compromised account downloads large volumes of confidential files and uploads them externally.

Detection Workflow

File Access Activity

↓

Large Data Transfer

↓

SIEM Correlation

↓

Threshold Exceeded



Data Exfiltration Alert



SOC Investigation

Workflow Explanation

The SIEM analyzes file access logs and network traffic. Abnormal outbound transfers or large downloads trigger alerts.

Detection Logic

Generate Alert If:

Data Transfer > 5 GB

AND

Destination External

THEN

Generate Exfiltration Alert

Example

20 GB Download

External Cloud Storage Upload

Log Sources

- Proxy Logs
- DLP Solutions
- Firewall Logs
- Cloud Audit Logs

Severity

CRITICAL

False Positives

- Legitimate backups
- Large business file transfers

Response Actions

- Block transfer
- Disable account
- Investigate accessed files

Tuning Recommendations

- Baseline user behavior
- Monitor sensitive departments separately

Use Case 5: Ransomware Behavior Detection

Description

Detects file encryption activity and ransomware execution behavior.

Threat Scenario

An attacker executes ransomware that encrypts thousands of files and deletes backup copies.

Detection Workflow

Endpoint Activity

↓

Mass File Modifications

↓

SIEM Correlation

↓

Encryption Detected

↓

Ransomware Alert

↓

Containment

Workflow Explanation

Endpoint telemetry identifies rapid file changes, encryption behavior, and backup deletion commands. The SIEM correlates these events and generates a critical ransomware alert.

Detection Logic

Generate Alert If:

Modified Files > 1000

AND

vssadmin delete shadows

OR

Backup Service Disabled

THEN

Generate Ransomware Alert

Example

vssadmin delete shadows

Log Sources

- EDR
- Sysmon
- Windows Event Logs
- Antivirus Logs

Severity

CRITICAL

False Positives

- Mass software deployments
- Backup maintenance operations

Response Actions

- Isolate endpoint immediately
- Disable compromised accounts
- Preserve forensic evidence
- Begin recovery process

Tuning Recommendations

- Exclude backup servers

- Correlate multiple ransomware indicators

Alert Triage Guide

Severity	Analyst Action	Response Time
Low	Monitor	24 Hours
Medium	Investigate	8 Hours
High	Escalate to L2	1 Hour
Critical	Immediate Response	15 Minutes

False Positive Analysis

Use Case	Potential False Positives
PowerShell	Legitimate administrative scripts
Brute Force	Users forgetting passwords
Privilege Escalation	Approved administrator changes
Data Exfiltration	Authorized file transfers
Ransomware	Backup operations

False Positive Reduction Strategies

- Behavioral baselining
- Asset criticality awareness
- User risk scoring
- Threat intelligence correlation
- Approved activity whitelisting

Tuning Recommendations

Phase 1

- Baseline user activity
- Identify normal administrative behavior

Phase 2

- Integrate threat intelligence feeds
- Add UEBA correlation

Phase 3

- Develop automated SOAR playbooks
- Implement risk-based alerting

Phase 4

- Continuous rule validation
- Monthly detection tuning reviews

Final SOC Recommendation Report

Based on the assessment, the organization should prioritize:

1. Enhanced PowerShell monitoring
2. Strong privileged account monitoring
3. Ransomware-specific behavioral detection
4. Data exfiltration monitoring
5. Identity-based threat detection
6. SIEM and EDR integration
7. Threat intelligence enrichment
8. Automated containment through SOAR

Expected Benefits:

- Reduced attacker dwell time
- Improved detection accuracy
- Faster incident response
- Enhanced visibility across the environment
- Reduced ransomware impact

Evaluation Criteria

Evaluation Criteria	Weightage
Detection Quality	30%
MITRE ATT&CK Mapping	20%
SOC Practicality	20%
False Positive Analysis	15%
Reporting Quality	15%

Detection Quality (30%)

Measures the effectiveness, accuracy, completeness, and real-world applicability of the detection use cases.

MITRE ATT&CK Mapping (20%)

Evaluates alignment between detection logic and MITRE ATT&CK tactics, techniques, and procedures.

SOC Practicality (20%)

Assesses operational feasibility, deployment readiness, and investigation effectiveness.

False Positive Analysis (15%)

Measures the quality of false-positive identification and tuning recommendations.

Reporting Quality (15%)

Evaluates professionalism, structure, technical accuracy, and completeness of documentation.

Conclusion

This Detection Engineering Assessment successfully delivers enterprise-grade security detections focused on ransomware, credential attacks, privilege escalation, data exfiltration, and malicious PowerShell execution. The proposed use cases provide comprehensive visibility across critical attack stages while aligning with MITRE ATT&CK, SOC operational requirements, and modern cybersecurity best practices.

By implementing these detections, the organization can significantly improve threat detection capabilities, reduce attacker dwell time, strengthen incident response processes, and enhance overall security resilience.